



FFIEC Information Technology Examination Handbook

Architecture, Infrastructure, and Operations

JUNE 2021

Contents

INTRODUCTION.....	1
I.....ARCHITECTURE, INFRASTRUCTURE, AND OPERATIONS.....	2
II.....ARCHITECTURE, INFRASTRUCTURE, AND OPERATIONS	
GOVERNANCE	3
II.A Board and Senior Management Responsibilities	4
II.A.1 Strategic Planning	6
II.A.2 Enterprise Risk Management.....	7
II.B Other Roles and Responsibilities	7
II.B.1 IT Management Responsibilities	8
II.B.1(a) Chief Architect	8
II.B.1(b) Chief Data Officer	9
II.B.1(c) IT Operations Management.....	10
II.B.2 IT Operations Personnel Responsibilities	10
II.C Policies, Standards, and Procedures	11
II.D Internal Audit, Independent Reviews, and Certification Processes	12
II.E Communication	13
II.F Board and Senior Management Reporting.....	13
III.....COMMON AIO RISK MANAGEMENT TOPICS	15
III.A Data Governance and Data Management.....	15
III.A.1 Data Identification and Classification	16
III.A.2 Database Management.....	17
III.A.2(a) Database Security	18
III.A.3 Non-Production Environments	19
III.A.4 Data Analytics	20
III.B IT Asset Management	22
III.B.1 Technology Asset Inventory	23
III.B.1(a) Hardware Inventory	24
III.B.1(b) Software Inventory	25
III.B.2 IT Asset End-of-Life	26
III.B.3 Shadow IT	27
III.C IT and Business Environment Representations.....	28
III.C.1 Network Diagrams.....	30
III.C.2 Data Flow Diagrams.....	31

III.C.3	Business Process Diagrams and Narratives	33
III.D	Managing Change in AIO.....	34
III.D.1	Change Management.....	35
III.D.2	Transitioning From Strategic Change Management to Day-to-Day Operations.....	37
III.E	Oversight of Third-Party Service Providers.....	37
III.F	Resilience	38
III.G	Remote Access	39
III.H	Personally Owned Devices.....	41
III.I	File Exchange	41
IV	ARCHITECTURE.....	43
IV.A	Architecture Plan	44
IV.B	Design Objectives	44
IV.C	IT Architecture Design.....	46
IV.D	Enterprise Architecture	47
V	INFRASTRUCTURE	49
V.A	Hardware.....	50
V.B	Network and Telecommunications	50
V.B.1	Network.....	51
V.B.2	Telecommunications	52
	V.B.2(a) Voice Communications.....	53
	V.B.2(b) Data Communications	54
V.C	Software.....	55
V.C.1	Internally and Externally Developed Software.....	55
V.C.2	Software Types	56
	V.C.2(a) Open Source Software	59
	V.C.2(b) Mainframe Security Software.....	59
	V.C.2(c) Application Programming Interfaces	60
V.C.3	Software Hosting.....	62
V.D	Environmental Controls.....	63
V.D.1	Heating, Ventilation, and Air Conditioning.....	64
V.D.2	Smoke and Fire.....	64
V.D.3	Water	65
V.D.4	Power	65
V.E	Physical Access Controls	66

VI	OPERATIONS	67
VI.A	Operational Controls	67
VI.A.1	Operating Centers	68
VI.A.2	Authorization Boundary	69
VI.A.3	Identity and Access Management	69
VI.A.4	Personnel Controls	70
VI.B	IT Operational Processes	71
VI.B.1	Maintenance	71
VI.B.2	Configuration Management	72
VI.B.3	Vulnerability and Patch Management	73
VI.B.3(a)	Vulnerability Management	73
VI.B.3(b)	Patch Management	74
VI.B.4	Backup and Replication Processes	75
VI.B.5	Scheduling	76
VI.B.6	Capacity Management	76
VI.B.7	Log Management	77
VI.B.8	Disposal of Data and Media	78
VI.C	Service and Support Processes	79
VI.C.1	Service Management	79
VI.C.2	Operational Support	80
VI.C.3	IT Support	80
VI.C.4	Event, Incident, and Problem Management	82
VI.D	Ongoing Monitoring and Evaluation Processes	83
VI.D.1	Monitoring and Reporting	84
VI.D.2	IT and Operations Key Performance Indicators	84
VI.D.3	Control Self-Assessments	85
VI.D.4	Continuous Improvement	85
VII	EVOLVING TECHNOLOGIES	87
VII.A	Cloud Computing	87
VII.A.1	Essential Characteristics	87
VII.A.2	Cloud Service Models	88
VII.A.3	Cloud Deployment Models	89
VII.A.4	Shared Responsibilities	90
VII.A.5	Risk Considerations for Cloud Computing	91
VII.A.5(a)	Access Control Considerations	92
VII.B	Zero Trust Architecture	93

VII.C	Microservices	94
VII.D	Artificial Intelligence and Machine Learning	96
VII.E	Internet of Things.....	97
APPENDIX A: EXAMINATION PROCEDURES		99
APPENDIX B: GLOSSARY		132
APPENDIX C: ABBREVIATIONS.....		151
APPENDIX D: REFERENCES.....		153

INTRODUCTION

The “Architecture, Infrastructure, and Operations” booklet is one in a series of booklets that compose the *Federal Financial Institutions Examination Council (FFIEC)*¹ *Information Technology Examination Handbook (IT Handbook)*. The *IT Handbook* is prepared for use by examiners.² With the publication of this booklet, the FFIEC member agencies replace the “Operations” booklet issued in July 2004. The title change reflects the overall importance of an entity’s architecture, infrastructure, and operations (AIO). For *IT Handbook* purposes, the term “entities” includes depository financial institutions,³ nonbank financial institutions,⁴ bank holding companies,⁵ and third-party service providers.⁶

This booklet discusses enterprise-wide, process-oriented approaches that relate to the design of technology within the overall business structure, implementation of IT infrastructure components, and delivery of services and value for customers. It discusses the following:

- Principles and practices for IT and operations as they relate to safety and soundness, consumer financial protection, and compliance with applicable laws and regulations.
- Processes for addressing risk related to the design and implementation of IT systems.
- Principles to help examiners evaluate the delivery of financial products and services.
- Management oversight of AIO and its related components, including governance; common risk management topics; specific activities of AIO; and evolving technologies that examiners may encounter during their reviews.

This booklet does not impose requirements on entities. Instead, this booklet describes principles and practices that examiners review to assess an entity’s AIO functions. Appendix A of this booklet provides objectives-based examination procedures. The application of the principles and related examination procedures may vary according to an entity’s complexity and risk profile.

¹ The FFIEC was established on March 10, 1979, pursuant to Title X of the Financial Institutions Regulatory and Interest Rate Control Act of 1978, Pub. L. 95-630. The FFIEC members are the Board of Governors of the Federal Reserve System (FRB), the Consumer Financial Protection Bureau (CFPB), the Federal Deposit Insurance Corporation (FDIC), the National Credit Union Administration (NCUA), the Office of the Comptroller of the Currency (OCC), and the State Liaison Committee (SLC).

² Each FFIEC member agency uses the principles outlined in this booklet, consistent with the member agency’s supervisory authority.

³ The term “depository financial institution” includes national banks, federal savings associations, state savings associations, state member banks, state nonmember banks, and credit unions.

⁴ The term “nonbank financial institution” includes non-depository financial institutions under the jurisdiction of either state banking departments or the CFPB.

⁵ The term “bank holding company” includes any company that has control over any bank or over any company that is or becomes a bank holding company as defined by the Bank Holding Company Act.

⁶ The term “third-party service providers” means third parties that provide services, the provision of which is subject to examination under the Bank Service Company Act, the Home Owners’ Loan Act, the Dodd–Frank Wall Street Reform and Consumer Protection Act, or other relevant law.

I ARCHITECTURE, INFRASTRUCTURE, AND OPERATIONS

This booklet provides a foundation for understanding the principles and practices within the functions of AIO. Architecture, infrastructure, and operations are separate but related functions that, together, management should oversee to appropriately manage an entity's activities related to designing, building, and managing the entity's technology. For the purposes of this booklet, the functions are referred to as AIO. The functions of AIO comprise a variety of activities, such as network and application design within architecture; selection and placement of physical and virtual technologies within infrastructure; and configuration, deployment, and maintenance of the infrastructure that supports the business within operations. The following definitions and descriptions provide an overview of the IT environment.⁷

Architecture refers to the manner in which the strategic design of the hardware and software infrastructure components (e.g., devices, systems, and networks) are organized and integrated to achieve and support the entity's business objectives. Planning and designing an effective IT architecture facilitate management's ability to implement infrastructure that aligns with the entity's strategic goals and business objectives.

Infrastructure refers to the physical elements, products, and services necessary to provide and maintain ongoing operations to support business activity and includes the maintenance of physical facilities. The focus of this booklet is on IT infrastructure, which is a subset of infrastructure and includes hardware, network and telecommunications, software, IT environmental controls (e.g., power, heating, ventilation, and air conditioning [HVAC]), and physical access. Once built and implemented, IT infrastructure can be managed internally or by a third-party service provider as part of the operations function.

Operations are the performance of activities comprising methods, principles, processes, procedures, and services that support business functions. Operations transform resource or data inputs into desired products, services, or results, and help in the creation and delivery of business value to internal and external customers. Operations include the ongoing maintenance, monitoring, and support for business systems, products, and services. This booklet addresses IT operations in the context of tactical management and daily delivery of services to support the overall business processes of the entity.

The principles and practices of the AIO functions outlined in this booklet are important for an effective IT environment. They support an entity's business lines and delivery of products and services to meet strategic business objectives. Inadequate coordination and oversight of these principles and practices may result in various risks (e.g., credit, liquidity, operational, compliance, and reputation).

⁷ The IT environment is the environment in which the entity directly operates, including direct interactions with the entity's third-party service providers.

II ARCHITECTURE, INFRASTRUCTURE, AND OPERATIONS GOVERNANCE

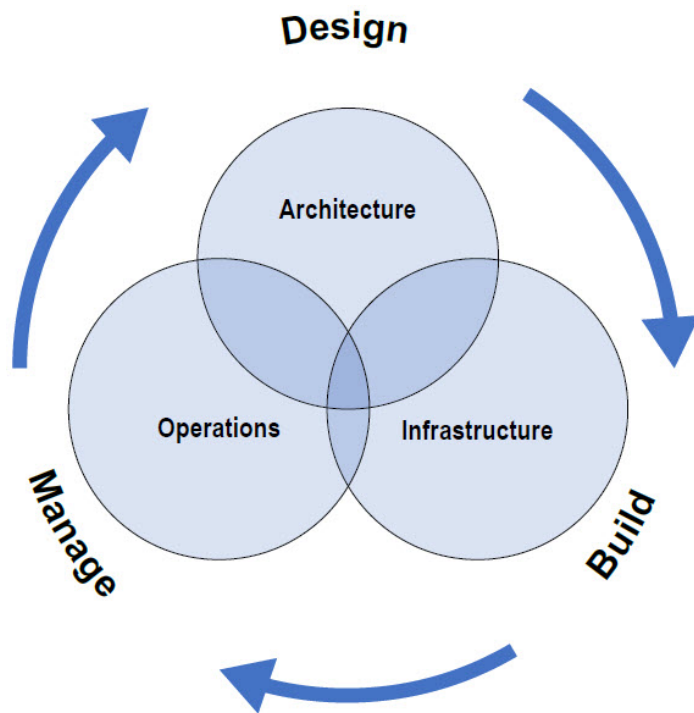
This section provides information about the governance of the AIO functions, including board and senior management responsibilities. General information about governance and risk management is contained in the *IT Handbook's* "[Management](#)" booklet and other member agency guidance.

Management should implement a process, such as a life cycle approach, to continuously manage technology to support operational needs and mitigate AIO-related risks. Figure 1 identifies the actions associated with this process for changing the architecture design to address evolving strategic and technology needs, building infrastructure that accommodates architecture changes, and managing technology in day-to-day operations.

To address risks, management should employ effective governance that includes the following:

- Delineation of board and senior management responsibilities.
- Strategic planning.
- Enterprise risk management (ERM).
- Delineation of other roles and responsibilities.
- Policies, standards, and procedures.
- Internal audit, independent reviews, and certifications.
- Communications.
- Board and senior management reporting.

Figure 1. Example of Life Cycle Approach for Governing AIO Risk



II.A Board and Senior Management Responsibilities

Action Summary

The board is responsible for overseeing, and senior management is responsible for implementing and maintaining, a safe and sound operating environment that supports the entity's goals and objectives and complies with applicable laws and regulations. Management should establish responsibility and accountability for the administration of the day-to-day functions of the IT environment.

Examiners should review for the following:

- Board regularly receives reports on AIO functions and activities from management.
- Discussions regarding AIO with the board are captured in meeting minutes.
- Tracking mechanisms and processes are in place to monitor issues related to AIO to their resolution.

The board,⁸ or its designated committee, and senior management should consider the entity's business objectives when governing the functions of AIO, including functions performed by affiliates and third-party service providers. Management should identify and evaluate risks

⁸ Most financial institutions have boards of directors; not all third-party service providers do. When an entity does not have a board, the senior leaders may have the responsibilities of the board described in this booklet.

associated with AIO, set short- and long-term objectives, and create policies and procedures to mitigate those risks. Furthermore, management should consider security and resilience in the design of new products and services.

Board oversight practices should include the following:

- Aligning AIO principles and practices with the board's strategic plans and risk appetite.
- Budgeting appropriate resources to support AIO activities.
- Ensuring board members have appropriate knowledge of risks to provide a credible challenge⁹ to management responsible for AIO functions.
- Enabling appropriate management training on AIO to carry out its responsibilities and manage risk.
- Reviewing AIO operating results and performance through audit reports, testing results, and management assessments and reports.

Management oversight should include the following:

- Validating through audits and other independent assessments that the following are comprehensive, meet enterprise-wide business and strategic plan objectives, and can assist in the identification of AIO risks:
 - Architectural designs and integration across the entity (e.g., business units and other departments).
 - Infrastructure testing (e.g., network performance, penetration testing, and vulnerability assessments).
 - Operational testing (e.g., functional testing and operational resiliency).
- Addressing risks self-identified by management, from AIO-related audits, and from other independent assessments, including the following risks:
 - Architectural risks, such as a lack of stakeholder communication, inadequate requirements planning, lack of documented architecture review, and insufficient planning for aging architecture.
 - Infrastructure-related risks, such as under- or over-provisioning because of poor capacity planning, hardware or software incompatibility, and migration problems.
 - Operational risks, such as deficient IT asset management (ITAM), inadequate access management processes, equipment failures, inadequate processes for system updates, computer attacks, insider threats, disasters, and lack of qualified operations personnel.
- Assessing and updating management's AIO strategies and plans to reflect the current business conditions and operating environment for continuous improvement.
- Promoting alignment and integration between functions of AIO.

⁹ A credible challenge involves being actively engaged, asking thoughtful questions, and exercising independent judgment.